

Mapeo de preguntas de la Encuesta COBIT a requisitos normativos y marcos

Nota: Mapeo de alto nivel; debe adaptarse a la normativa específica de cada sector y país.[web:18]
[web:24][web:43]

Nº Pregunta	Tema resumido	Objetivo COBIT principal	Marcos y normas relacionados (ejemplos)
P1.1.1	Frecuencia de revisión por órgano de gobierno	EDM03 – Ensured Risk Optimization	Código de Buen Gobierno, NIS2 (gobernanza), ENS (principios)
P1.1.2	Informes de ciberseguridad al órgano de gobierno	EDM03, MEA01	NIS2 (gestión de riesgos), ISO 27001 (cláusula 5.1)
P1.2.1	Apetito y tolerancia al riesgo	EDM03, APO12	ISO 31000, COSO ERM, NIS2 (gestión riesgos)
P1.2.2	Revisión del apetito al riesgo	EDM03	Buen gobierno corporativo, ISO 31000
P2.1.1	Proceso formal de gestión de riesgos de TI	APO12 – Managed Risk	ISO 27001 (A.6, A.8), ENS, NIS2
P2.1.2	Cobertura del proceso de riesgos	APO12	ISO 27005, NIST SP 800-30
P2.2.1	Cobertura de activos críticos con análisis de riesgos	APO12	ISO 27001 (A.8), ENS (ANEXO II)
P2.2.2	Frecuencia de revisión de análisis de riesgos	APO12, MEA01	ISO 27005, ENS (revisión periódica)
P3.1.1	Existencia y madurez del SGSI	APO13 – Managed Security	ISO 27001, ENS, NIS2
P3.1.2	Alineamiento / certificación ISO 27001	APO13	ISO 27001, esquemas de certificación nacionales
P3.2.1	Función de seguridad (CISO)	APO13, EDM03	NIS2 (responsabilidades), ENS (organización)
P3.2.2	Porcentaje de presupuesto TI en seguridad	APO13, EDM03	Buenas prácticas de gobernanza TI, informes sectoriales
P4.1.1	Evaluación de seguridad en cambios	BAI06 – Managed IT Changes	ISO 27001 (A.8, A.14), ITIL, ENS
P4.1.2	Pruebas de seguridad en cambios	BAI06, DSS05	ISO 27001 (A.12, A.14), DevSecOps guías sectoriales
P4.2.1	Incidentes debidos a cambios mal gestionados	BAI06, DSS02	ISO 27001 (A.16), NIST CSF (Identify/Protect)
P5.1.1	Capacidades SOC / monitorización	DSS05 – Managed Security Services	NIS2 (detección), ENS (detección), NIST CSF (Detect)

P5.1.2	MTTD de incidentes significativos	DSS05, MEA01	NIST CSF (Detect/Respond), guías de MSSP
P5.2.1	MTTR de incidentes significativos	DSS05, DSS02	NIST CSF (Respond/Recover), ISO 27035
P5.2.2	% vulnerabilidades críticas resueltas en plazo	DSS05, APO12	ISO 27001 (A.12), NIST SP 800-40
P6.1.1	Existencia y pruebas BCP/DRP	DSS04 – Managed Continuity	ISO 22301, ISO 27001 (A.17), ENS
P6.1.2	Simulacros de ciber crisis con dirección	DSS04, EDM03	NIST CSF (Respond/Recover), guías de ciberresiliencia
P7.1.1	Cuadro de mando de ciberseguridad	MEA01 – Performance and Conformance Monitoring	NIS2 (monitorización), ISO 27004
P7.1.2	Periodicidad revisión de indicadores	MEA01, EDM03	Buen gobierno de TI, ISO 27004
P7.2.1	Frecuencia de auditorías de seguridad	MEA02 – System of Internal Control	ISO 27001 (auditorías), ENS, regulaciones sectoriales
P7.2.2	Acciones correctivas cerradas en plazo	MEA02, MEA03	ISO 27001 (no conformidades), marcos de compliance
P8.1	Madurez global autoevaluada	Todos (CPM COBIT 2019)	COBIT 2019 Performance Management, modelos de madurez 0-5
P8.2 / P8.3	Fortalezas y debilidades declaradas	Transversal	Planes estratégicos de ciberseguridad, NIS2, ENS

Este mapeo proporciona una guía rápida para vincular resultados de la encuesta con obligaciones normativas y marcos de referencia, facilitando el diseño de planes de mejora.